

Rules of the Game

Security models, policies and the network we defend

- 1 Networks 101 for defenders
- 2 Security policies and the ladder
- 3 Access-control principles and models
- 4 Law and ethics: no permission, no testing
- 5 Defence in depth: the McCumber cube

Hour 1 · five lessons · 60 minutes · Binder Part 2 due Wednesday, October 7, 23:59



Cyber.SoHo — Educational Hub

*From the Industry to the Classroom — Building the IT's
Future, Today and Together !*

Authorization first — before any lab

1 Designated lab systems only

Every scan, test or “attack” happens only on the lab systems and the fictional BlueFern Trading Inc. scenario — with explicit, written authorization.

2 No OSINT (Open-Source Intelligence) on real people or organizations

Everything you investigate in this course is fictional on purpose. Never research a real person or a real company.

3 Not sure? Then you are not authorized

Stop and ask before you act. The same act on any other system is a criminal offence, whatever the intention.

The law behind the rule

- Canada — [Criminal Code s. 342.1](#)
- United States — [CFAA, 18 U.S.C. § 1030](#)
- European Union — [Directive 2013/40/EU](#)
- Spain — [Ley Orgánica 10/1995](#)

Full rules: [Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy \(v2.0\)](#)

Your acknowledgement (Annex A) is signed before the first laboratory — the form is provided separately.



Today's hour at a glance

LESSON 1 · 0:00–0:14

Networks 101 for defenders

Activity: trace an order on the board

LESSON 2 · 0:14–0:28

Security policies

Activity: which policy is missing?

LESSON 3 · 0:28–0:42

Access control

Activity: seven terms, flash-cards

LESSON 4 · 0:42–0:52

Law and ethics

Activity: legal or not?

LESSON 5 · 0:52–1:00

Defence in depth

Activity: two controls + Zen break

The one FACT

Your weekly work is not homework on the side. It **IS** the project — and the project **IS** your exam preparation.

Mid-Term: Thursday, November 19, 2026 · Final: Thursday, January 21, 2027 · every Binder Part is due Wednesday, 23:59.

This afternoon

- Exercise 2.1 — network map with trust zones
- Exercise 2.2 — two policies
- Exercise 2.3 — **RBAC** (Role-Based Access Control) role matrix
- → Binder Part 2, due Wednesday, October 7, 23:59



Hosts, packets — and what every log line contains

- A **network** is a set of computers connected so that they can exchange data; each connected computer is a **host**.
- Data travels in **packets**: a **header** (the addressing and control information) plus a **payload** (the content).
- Every device on the path handles each packet on its own: packets of one conversation can take different routes, and a lost packet is resent alone.
- Scanners count open ports, firewalls filter on addresses and ports, **IDS** (Intrusion Detection System) sensors read packets — the evidence always holds an **address**, a **port** and a **protocol**.

One packet

HEADER

source and destination
address · ports · protocol

PAYLOAD

the content: an order, a page, a file

What a defender reads in every log line

ADDRESS

which machine

PORT

which program

PROTOCOL

how it is delivered

Scope: CS 474 looks at the network only as the path by which data reaches the machines, the software and the data we protect.



IP addresses: public, private, /24 and NAT

- An **IP (Internet Protocol) address** identifies a host's network interface. **IPv4 (Internet Protocol version 4)**: 32 bits, four numbers from 0 to 255 — BlueFern's web shop is 203.0.113.25. (**IPv6 (Internet Protocol version 6)** uses 128 bits.)
- **Public** addresses are unique on the Internet and reachable from anywhere.
- **Private** addresses — 10.x.x.x, 172.16–31.x.x, 192.168.x.x ([RFC 1918](#)) — are reused in every office and never routed on the Internet.
- **Prefix length /24**: the first 24 bits name the network, the last 8 name the host → 254 usable addresses.
- **NAT (Network Address Translation)**: the office router swaps each private address for the office's single public address on the way out, and back on the way in.

The warehouse scanner 192.168.10.40, in four bytes



Warehouse scanner
192.168.10.40 (private)



Office router
NAT



The Internet sees
the office's one public address

An attacker on the Internet cannot address the scanner directly — but the scanner can still reach out.



Ports: which program on the host

- An address names the machine; a **port** — a 16-bit number, 0 to 65535 — names the program on it.
- A server **listens** on an agreed **well-known port** (0–1023, assigned by [IANA](#)).
- The client uses a temporary **ephemeral port** (49152–65535) for each conversation.
- Address + port = a **socket**; one connection = two sockets.

53 DNS

80 HTTP

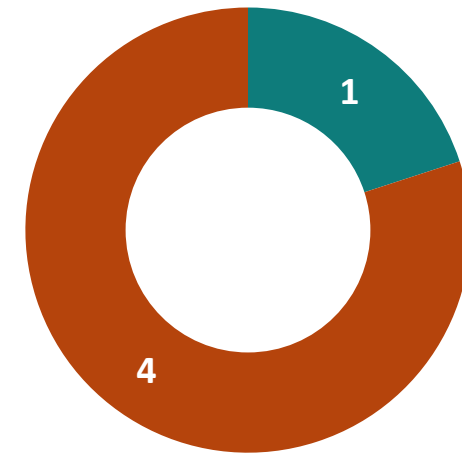
443 HTTPS

22 SSH

21 FTP

3306 MySQL

203.0.113.25 today: five ports open to the whole Internet



■ Needed by customers: 443 ■ Wrong exposure: 21, 22, 80, 3306

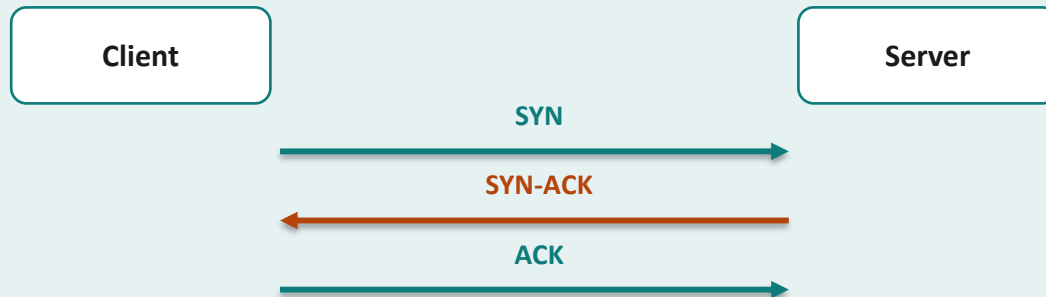
Only **443** needs to be reachable by customers. Class 4 will scan exactly these five ports.



TCP and UDP: two ways to deliver

TCP — connection-oriented

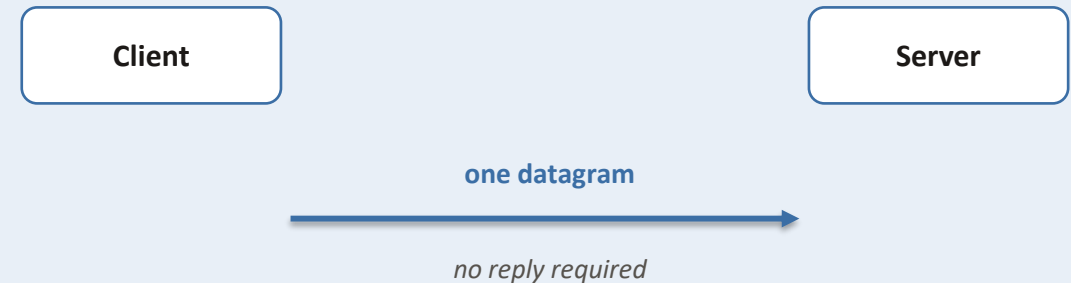
Transmission Control Protocol



- Every byte numbered, acknowledged and retransmitted if lost → **reliable, ordered** delivery
- Used by **HTTP** (HyperText Transfer Protocol) and **HTTPS** (HyperText Transfer Protocol Secure), **SSH** (Secure Shell), mail, databases

UDP — connectionless

User Datagram Protocol

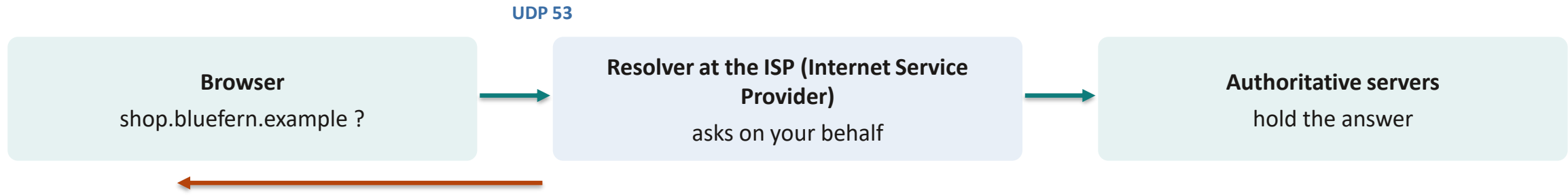


- One **datagram**, no handshake, no acknowledgement, no guarantee — the application copes with loss
- Fast and light: **DNS** (Domain Name System), **NTP** (Network Time Protocol) time synchronization, voice and video

Why defenders care: a scanner calls a port open when it receives SYN-ACK • a **SYN (Synchronize) flood** (Class 6) starts handshakes it never finishes • **UDP's** missing handshake makes forged source addresses easy (amplification).



DNS: from names to addresses



Answer: **A record** shop.bluefern.example = 203.0.113.25 · **TTL (Time To Live)** 300 seconds

- **DNS (Domain Name System)** is the distributed database that maps names (for people) to addresses (for packets).
- The **resolver** fetches the A record and returns it with a **TTL**: the number of seconds the answer may be cached.
- It runs over **UDP** (User Datagram Protocol) port 53 and is not encrypted by default — anyone on the path can read which names you look up.

DNS spoofing

A forged answer sends every customer to a fake shop — without touching BlueFern's server.

Look-alike names

Phishing domains are **DNS** entries too: read every domain letter by letter ([Legal Notice, Annex C](#)).



HTTP and HTTPS: in the clear, and encrypted

HTTP (HyperText Transfer Protocol) · port 80

- **Request:** method (GET, POST), path (/checkout), headers, body
- **Response:** status code 200 · 404 · 500, then the content
- **Stateless:** a **cookie** carries the session
- Clear text: a capture reads every field

What a capture on the café Wi-Fi shows

```
POST /checkout HTTP/1.1
name=M.+Tremblay&card=4111 1111 1111 1111
```

HTTPS (HyperText Transfer Protocol Secure) · port 443 = HTTP inside TLS (Transport Layer Security)

- **Encryption** — a capture shows only ciphertext
- **Authentication** — the server's **certificate**, issued by a **CA (Certificate Authority)**, is what the padlock checks
- **Integrity** — a modified packet is detected

What a capture on the café Wi-Fi shows

```
17 03 03 01 2f 8a 4e c1 9d 03 f7 b2 6e 51 0a d8...
(ciphertext)
```

BlueFern accepts plain **HTTP** on port 80 without redirecting. **Rule: port 80 only redirects to 443.**



Micro-activity — the order’s journey, on the board (4 min)

Draw with us — seven nodes

- 1 Customer phone (café)
- 2 ISP (Internet Service Provider) / café router
- 3 DNS (Domain Name System) resolver
- 4 Web-shop VM (Virtual Machine) 203.0.113.25
- 5 MySQL (same VM)
- 6 Payment gateway
- 7 Warehouse scanner on the LAN (Local Area Network)

Three questions while we draw

- 1 Where on this route could someone read the packet?
- 2 Which of the server’s five open ports does the order actually use?
- 3 What is the difference between the customer’s address and the warehouse scanner’s address?

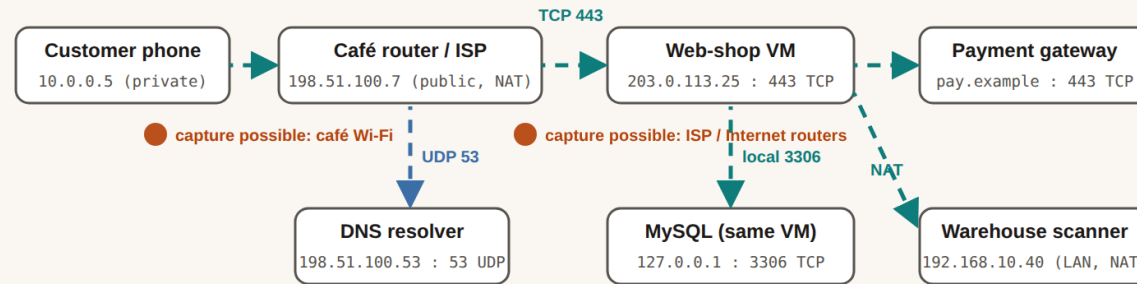
Keep the drawing: **Exercise 2.1** turns it into BlueFern’s network map.



Schematic — the packet's journey

The packet's journey - one order, from a café to BlueFern Trading Inc. and back

Every hop is a socket (address : port); UDP for DNS, TCP for everything else; only TLS hides the content (Lesson 1)



TCP three-way handshake before any HTTPS data



then TLS: certificate + keys -> ciphertext from here on

DNS: one UDP datagram out, one back - no handshake,
no encryption by default

Ports open on 203.0.113.25 today

21 FTP	remove - SFTP over SSH via VPN
22 SSH	VPN range only, keys, patch
80 HTTP	redirect to 443 only
443 HTTPS	open - the shop
3306 MySQL	127.0.0.1 only - firewall

4 of 5 exposures are wrong - the Class 4 scan will print exactly this list

IP address = which machine | port = which program | socket = address : port | private 192.168.x / 10.x are never routed on the Internet (NAT)

Cyber.SoHo - CS 474 Class 2 - Lesson 1 - addresses are documentation ranges (RFC 5737 / RFC 1918); company and traffic are fictional

The order's route with the socket used at every hop, the transport protocol (**UDP** (User Datagram Protocol) for **DNS** (Domain Name System), **TCP** (Transmission Control Protocol) for everything else), and the three places where a capture is possible. Right: the server's five open ports and what each should be.



Real-life example — one order, one route, five open ports

Task

Follow order ORD-1042 from a café to the web shop, its database, the payment gateway and the warehouse; record each packet's sockets, transport and readability.

How it relates to today

Addresses, ports, **TCP** (Transmission Control Protocol) and **UDP** (User Datagram Protocol), **HTTP** (HyperText Transfer Protocol) versus **HTTPS** (HyperText Transfer Protocol Secure) — every term of Lesson 1 on one route.

Where it returns

Exercise 2.1 today → **Binder Part 2** (network map). Then Part 4 (scan of these five ports), Part 6 (firewall and **IDS** (Intrusion Detection System) placement), Part 8 (**DMZ** (Demilitarized Zone) and VLANs).

Packet Journey Tracer - one customer order, from a phone to the BlueFern Trading Inc. web shop and back

Each step moves one packet along the route and shows its source and destination (IP address and port), the transport protocol (TCP or UDP), and what a person capturing the traffic would see. The port table shows which services the web-shop server exposes. Pause at any step to discuss it.

[Start](#) [Restart](#) [Copy log](#) [Copy code](#) [Download packet log \(CSV\)](#)

Step 13 of 14 - readable card data on the wire: pause and discuss.

The route (the rust dot is the packet; the rust border is the node it is visiting)

Addresses are documentation ranges (RFC 5737 / RFC 1918) - the company and the traffic are fictional

Packet in flight

From 198.51.100.7:52002
To 203.0.113.25:80
Transport TCP
Application HTTP (no TLS): POST /checkout - the same order

On the wire

```
POST /checkout HTTP/1.1
name=M.+Tremblay&address=1200+rue+Sainte-Catherine&card=4111 1111 1111 1
1116exp=09/28
```

Ports open on the web-shop server today (this is what a scan will show in Class 4)

Port	Transport	Service	Reachable from	Should be
21	TCP	FTP (vsftpd 2.3.4)	Whole Internet	Closed - use SFTP over SSH, restricted to the VPN

Execution steps (read this window when paused)

Step 12 - HTTPS: pick list for ORD-1042 (scanner polls the shop)
 203.0.113.25:443 -> 192.168.10.40:56000 [TCP]
 The warehouse scanner on the office LAN (192.168.10.0/24, a private address range) fetches the pick list. Private addresses are not routable on the Internet; the office router translates them to its public address on the way out.

Step 13 - HTTP (no TLS): POST /checkout - the same order
 198.51.100.7:52002 -> 203.0.113.25:80 [TCP]
 Counter-example: the same order sent to port 80 without TLS. The person at the next table in the café, capturing the Wi-Fi, reads the name, the address and the card number. This is why port 80 must only redirect to 443, and why 'HTTPS everywhere' is a rule, not a preference.

The interactive example in the lecture module and the hand-out: **Start • Pause • Restart • Copy • CSV (Comma-Separated Values)**; every step is explained in its log window.



Review — Lesson 1: videos and flash-cards

Watch — each under 15 minutes (click the title)



[The Internet - Crash Course Computer Science #29](#)

Crash Course / PBS Digital Studios (Carrie Anne Philbin) · about 12 min

DNS (Domain Name System) turns names into addresses, **IP** (Internet Protocol) carries the data in packets, and **TCP** (Transmission Control Protocol) versus **UDP** (User Datagram Protocol) — the whole lesson in one animation.



[Introduction to IP - CompTIA Network+ N10-008 - 1.5](#)

Professor Messer (Messer Studios) · 14:09

IP addresses, port numbers and **TCP** versus **UDP**, drawn as packet diagrams.

Flash-cards — say the answer before you turn the card

1

IP address and port

2

Public versus private address, and NAT (Network Address Translation)

3

TCP versus UDP

4

DNS

5

HTTP (HyperText Transfer Protocol) versus HTTPS (HyperText Transfer Protocol Secure)

The backs of the cards are in the hand-out and the lecture module.



Self-check — Lesson 1 (1/2): four questions, one answer each

1

A customer's phone sends the order to 203.0.113.25 on port 443. What does the port number identify?

- a) The physical network card of the server
- b) The version of the operating system
- c) The program (service) on the server that should receive the packet - here, the web server
- d) The country in which the server is located

2

Which sequence is the TCP (Transmission Control Protocol) three-way handshake?

- a) **SYN** (Synchronize), SYN-ACK, **ACK** (Acknowledgement)
- b) GET, 200 OK, cookie
- c) ClientHello, ServerHello, Certificate
- d) Query, answer, **TTL** (Time To Live)

3

Why does DNS (Domain Name System) normally use UDP (User Datagram Protocol) rather than TCP?

- a) Port 53 exists only for **UDP**
- b) **UDP** is encrypted and **TCP** is not
- c) **UDP** guarantees delivery better than **TCP**
- d) A query and its answer fit in one small datagram each, so the handshake and acknowledgements of **TCP** would be pure overhead

4

A person captures the café Wi-Fi while a customer submits an order to BlueFern over plain HTTP (HyperText Transfer Protocol) on port 80. What does the capture show?

- a) Only the **DNS** query, not the order
- b) The request in clear text, including the name, the address and the card data
- c) Only ciphertext, because Wi-Fi encrypts everything
- d) Nothing, because the packet uses a private address

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade.



Self-check — Lesson 1 (2/2): two questions, several answers each

5

Which of the following are provided by HTTPS (HTTP (HyperText Transfer Protocol) inside TLS (Transport Layer Security)) and not by plain HTTP? (select 3)

- a) Cookies that keep a customer logged in
- b) Encryption of the request and the response on the path
- c) Authentication of the server through a certificate issued by a certificate authority
- d) Status codes such as 200 and 404
- e) Faster delivery than HTTP
- f) Detection of packets modified on the path

6

Which two of BlueFern's open ports are the most dangerous exposures according to Lesson 1 and the port table? (select 2)

- a) 53 - DNS (Domain Name System)
- b) 443 - HTTPS, the web shop
- c) 21 - FTP (File Transfer Protocol), vsftpd 2.3.4 with a publicly known backdoor
- d) 587 - mail submission
- e) 123 - NTP (Network Time Protocol), clock synchronization
- f) 3306 - MySQL, the customer database, reachable from the Internet

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade. Answers and explanations: lecture module and hand-out.



What a security policy is — and why write one

Definition

A **security policy** is a formal, written statement of the rules an organization adopts to protect its information and systems — and of **who** is responsible for following and enforcing them.

Not a policy: “The **VPN** (Virtual Private Network) uses 256-bit encryption.” — a setting

A policy: “All remote access passes through the **VPN**; the **IT** (Information Technology) staff provide it.” — a rule and a responsibility

Test: if a sentence could be pasted into a configuration file, it is not a policy statement.

Five reasons to write it down

- 1 **Enforcement** — nobody can be held to a rule that was never written and communicated
- 2 **Consistency** — 38 people, one rule
- 3 **Compliance** — privacy law and the merchant contract ask for documented safeguards
- 4 **Measurability** — intentions become requirements an audit can check
- 5 **Defence** — policy and people are the first layer of defence in depth

BlueFern fails all five: “no written security policy”.



The ladder: policy, standard, procedure, guideline

POLICY

mandatory · general

“All remote access uses the **VPN** (Virtual Private Network).” Approved by management; changes rarely.

STANDARD

mandatory · specific, measurable

“The **VPN** requires **MFA** (Multi-Factor Authentication); the device has disk encryption, current patches, endpoint protection.”

PROCEDURE

mandatory · ordered steps

“1) request 2) **IT** (Information Technology) checks the baseline 3) profile installed 4) request recorded.”

GUIDELINE

recommended

“Prefer a company laptop; on public Wi-Fi connect the **VPN** first.”

Separate rungs

Each rung has a different author, reader and lifetime.

Wrong rung, weak document

A policy full of settings is obsolete in a year; a standard without a policy has no authority.

Baseline

A standard for one type of system — e.g. a [CIS Benchmark](#) for a Windows laptop (Class 5).

more specific → shorter lifetime



Five policy types you will meet all term

Acceptable use policy (AUP)

what staff may do with systems, data, Internet, social media, **USB** (Universal Serial Bus) · **BlueFern today:** USB copy of the customer list; staff photos posted

Password / account-management policy

individual accounts, no sharing, **MFA** (Multi-Factor Authentication) for administrators, leaver procedure · **BlueFern today:** one shared admin password; no **MFA**

BYOD (Bring Your Own Device) and remote-work policy

which devices may process company data, and how they connect · **BlueFern today:** personal laptops on café Wi-Fi, no **VPN** (Virtual Private Network)

Data classification policy

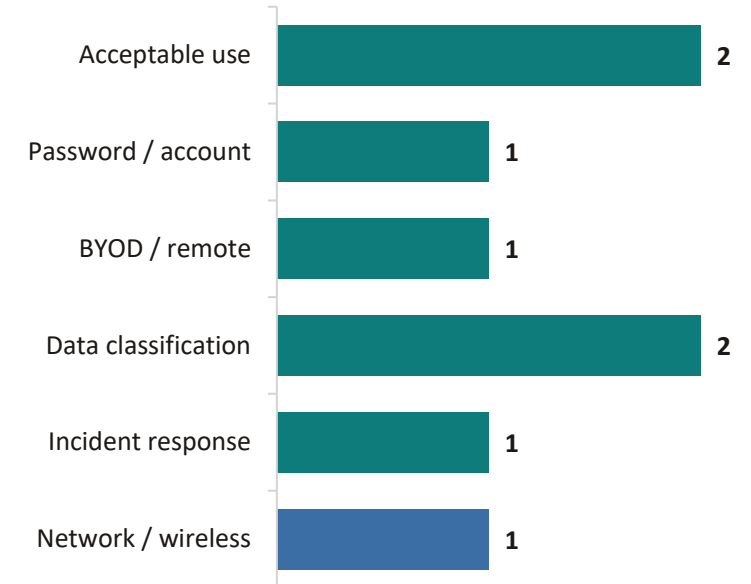
Public · Internal · Confidential · Restricted — and a handling rule for each · **BlueFern today:** everybody reads everything on the file server

Incident response policy

report every event; follow the incident plan (Class 6) · **BlueFern today:** ransom note — nobody knows whom to call

Around them: network and wireless access, change-management and backup policies.

Situations that need each type (Lesson 2 example)



Modern password rules

NIST SP 800-63B: length over forced complexity · screen against breached passwords · no forced periodic change.



The shape of a policy — and three failures to avoid

Eight sections — your Exercise 2.2 template

- 1 **Purpose** — why the policy exists
- 2 **Scope** — who and what it covers
- 3 **Roles and responsibilities** — who follows, who enforces
- 4 **Policy statements** — numbered, one rule each, using “must”
- 5 **Enforcement** — what happens on violation
- 6 **Exceptions** — who may approve one — in writing
- 7 **Review** — owner and date
- 8 **Approval** — who signed

Three common failures

Nobody has read it

communicate it, train it, and collect a written acknowledgement — as you will for the Legal Notice

No owner

it will never be reviewed

No enforcement

it becomes advice — a guideline with a grander title

One page is enough for an acceptable use policy in a company of 38 people.



Micro-activity — which policy is missing? (4 min)



One administrator password — BlueFern2019! — shared by the router, the file server and the web-shop admin panel.

Policy type? One sentence it would contain?



One Wi-Fi network for staff, warehouse scanners and visitors; the password is printed on the showroom wall.

Policy type? One sentence it would contain?



A resigning finance clerk copies the customer spreadsheet to a USB (Universal Serial Bus) drive.

Policy type? One sentence it would contain?



A remote worker on a personal laptop, on café Wi-Fi, without the VPN (Virtual Private Network).

Policy type? One sentence it would contain?

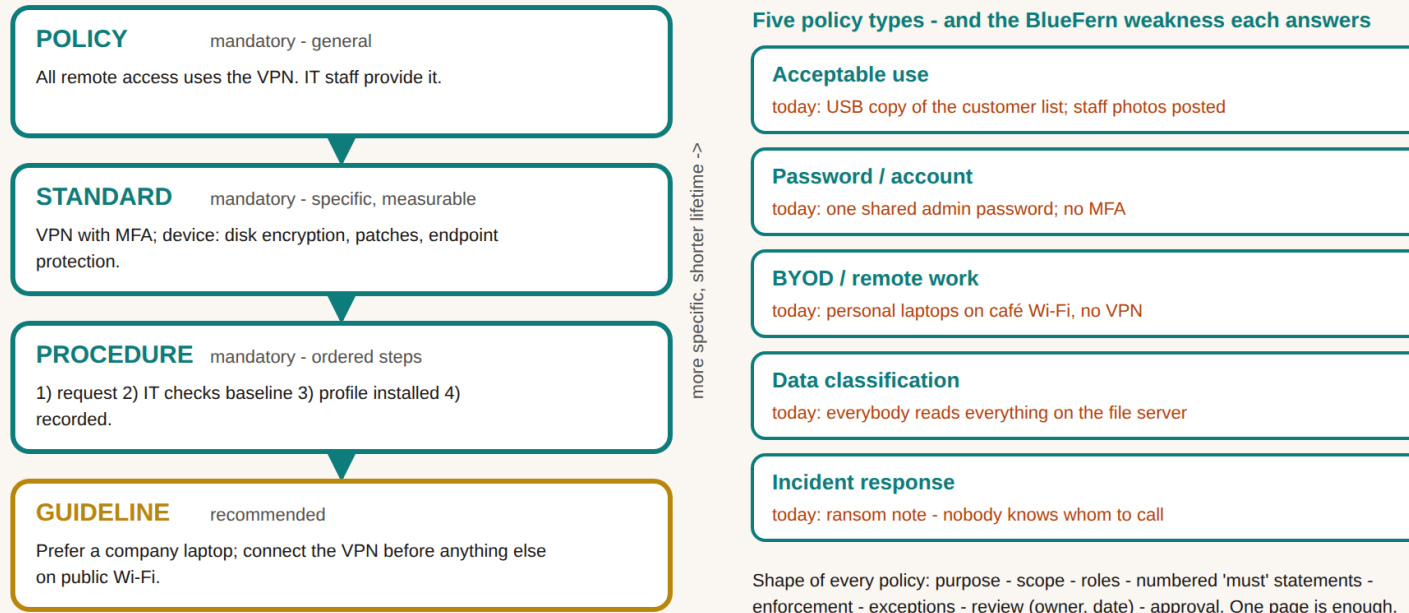
Name the policy type, then say one sentence the policy would contain. The interactive example adds two more situations and writes all four rungs.



Schematic — the ladder and the five policy types

The policy ladder - and the five policy types of this course

A policy states rules and responsibilities; the settings live lower down (Lesson 2)



Test: if a sentence could be pasted into a configuration file, it is not a policy statement.

Exercise 2.2 writes the two most-needed rows: the acceptable use policy (1 page) and the password policy (half a page).

Cyber.SoHo - CS 474 Class 2 - Lesson 2

Left: the four rungs, from general and mandatory (policy) to specific and recommended (guideline), with the **VPN** (Virtual Private Network) example on each rung. Right: the five policy types of this course and the BlueFern weakness each one answers.



Real-life example — which policy is missing? six situations

Task

Take six weaknesses from the BlueFern profile, name the policy type that should govern each, and write its four rungs: policy, standard, procedure, guideline.

How it relates to today

The definition of Lesson 2 applied to real weaknesses; the four rungs separated on concrete text.

Where it returns

Exercise 2.2 today (acceptable use + password policy) → **Binder Part 2**. Standards return in Part 5, procedures in Part 6, classification in Part 10.

Policy Ladder Builder - "which policy is missing?" at BlueFern Trading Inc.

Each situation from the company profile is matched to the policy type that should govern it; the coverage grid fills in, and for every situation the four rungs of the ladder are written: policy (the rule and who is responsible), standard (the measurable requirement), procedure (the steps), guideline (the recommendation). Pause at any step to discuss.

[Start](#)
[Restart](#)
[Copy log](#)
[Copy code](#)
[Download coverage table \(CSV\)](#)

Situation 3 of 6 - read the four rungs, then Resume.

Situation under analysis

3. A finance clerk who has resigned copies the customer spreadsheet to a USB drive on the last day. USB ports are open on every laptop.

Coverage grid - which policy type governs which situation

Situation	Acceptable use	Password / account	BYOD / remote work	Data classification	Incident response	Network / wireless
1. One administrator password - BlueFern2019!...		X				
2. One Wi-Fi network, BlueFern-Guest, is shar...						X
3. A finance clerk who has resigned copies th...	X			+		
4. About half of the remote workers connect f...						
5. Monday 08:10: a ransom note appears on the...						
6. Marketing posts photos of staff with						

Execution steps (read this window when paused)

classification)

Why: What employees may and may not do with company data and equipment is the acceptable use policy; the sensitivity of the spreadsheet is set by the data classification policy (the second column lit). A leaver procedure completes the picture.

Policy: Company data is used only for company purposes and never copied to personal media or accounts. Responsible: every employee; owners of the data (Head of Sales for customer data).

Standard: Customer data is classified Confidential: removable media blocked by endpoint configuration; exports require the data owner's written approval.

Procedure: 1) HR informs IT of the leaving date; 2) accounts disabled on the last day; 3) equipment returned and checked; 4) access review recorded.

Guideline: Keep customer data in the shared system; if an export is needed, use an approved encrypted channel and delete the copy after use.

The interactive example in the lecture module and the hand-out: **Start** • **Pause** • **Restart** • **Copy** • **CSV (Comma-Separated Values)**; every step is explained in its log window.



Review — Lesson 2: videos and flash-cards

Watch — each under 15 minutes (click the title)



[Security Policies - CompTIA Security+ SY0-701 - 5.1](#)

Professor Messer (Messer Studios) · 11:02

What a security policy is: acceptable use, continuity, incident response, change management.



[Security Standards - CompTIA Security+ SY0-701 - 5.1](#)

Professor Messer (Messer Studios) · 5:36

The second rung: password, access-control, physical-security and encryption standards.

Flash-cards — say the answer before you turn the card

1

Security policy

2

The ladder: policy - standard - procedure - guideline

3

Acceptable use policy (AUP)

4

Password and account policy (NIST (National Institute of Standards and Technology) SP (Special Publication) 800-63B)

5

The shape of a policy

The backs of the cards are in the hand-out and the lecture module.



Self-check — Lesson 2 (1/2): four questions, one answer each

1

Which sentence is a **POLICY** statement, as opposed to a standard, a procedure or a guideline?

- a) Prefer a company laptop for remote work
- b) All remote access to company systems passes through the **VPN** (Virtual Private Network); the **IT** (Information Technology) staff are responsible for providing it
- c) The **VPN** requires multi-factor authentication and 256-bit encryption
- d) Step 1: submit the access request; step 2: **IT** verifies the device; step 3: **IT** installs the profile

2

A resigning finance clerk copies the customer spreadsheet to a USB (Universal Serial Bus) drive. Which policy type primarily governs this situation?

- a) The network and wireless access policy
- b) The incident response policy
- c) The change-management policy
- d) The acceptable use policy (with the data classification behind it)

3

According to current NIST (National Institute of Standards and Technology) guidance (SP (Special Publication) 800-63B) reflected in Lesson 2, which password rule should a modern policy include?

- a) Check new passwords against lists of known breached passwords and favour length over forced complexity
- b) Share one strong administrator password among the **IT** staff to reduce the number of passwords
- c) Force every user to change the password every 30 days
- d) Require exactly 8 characters with one symbol

4

Why is a policy that nobody has read a failed control?

- a) It is not a failure: policies exist for auditors, not for employees
- b) Because reading a policy is a technical control
- c) It cannot be enforced: an employee cannot be held to a rule that was never communicated and acknowledged
- d) Because unread policies are automatically deleted by the system

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade.



Self-check — Lesson 2 (2/2): two questions, several answers each

5

Which of the following belong in the standard rung (mandatory and measurable), not in the policy rung? (select 3)

- a) Every suspected security event is reported immediately to the incident coordinator
- b) Prefer a four-word random passphrase
- c) Backups follow the 3-2-1 rule and are restore-tested monthly
- d) Company data is used only for company purposes
- e) The guest Wi-Fi is isolated from the office **LAN** (Local Area Network) and its password is rotated weekly
- f) Passwords have at least 14 characters or are random passphrases

6

Which sections belong in a well-formed policy document (the Exercise 2.2 template)? (select 4)

- a) The list of every employee's password
- b) Enforcement, exceptions, review date and approval
- c) Roles and responsibilities
- d) The firewall configuration file
- e) Purpose and scope
- f) Numbered policy statements using 'must'

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade. Answers and explanations: lecture module and hand-out.



Access control: subject, object, right



Subject

the active entity that asks: a user, or a process running on a user's behalf

Object

the passive resource asked for: a file, a folder, a database table, a network service, a printer

Access right

what the subject wants to do to the object: read, write, execute, delete, administer

A reference monitor is trustworthy only if it **(1) mediates every access, (2) cannot be bypassed or tampered with, (3) is small enough to be verified.**

In practice: the **OS** (Operating System) kernel for files, the database engine for tables, the web application for its own functions.

Access control is the technical form of **authorization** — the third check of a login (Class 1).



Four principles — and where BlueFern breaks them

1 Least privilege

Every subject receives the minimum rights its task requires, and no more.

BlueFern: 30 laptops, everyone a local administrator “to install printers”

2 Need-to-know

Access to specific information only when the task requires it — even if the role would allow it.

BlueFern: sales needs customer records, not the whole export

3 Separation of duties

A critical task is divided so that no single person can complete — or abuse — it unnoticed.

BlueFern: finance records AND approves payments

4 Implicit deny

Whatever is not explicitly permitted is refused: the absence of a permission is the refusal.

BlueFern: file server “everybody reads everything” = implicit allow



Three models: who decides?

DAC

Discretionary access control

Who decides: the **OWNER** of the object

- Rights listed in an **access control list** on the object
- File servers, Windows folders, Linux files
- Flexible — but discretion accumulates: owners grant, forget, leave

MAC

Mandatory access control

Who decides: the **SYSTEM**: label versus clearance

- A **label** on the object is compared with a **clearance** on the subject
- Military and government systems, **SELinux** (Security-Enhanced Linux), phone sandboxes
- Nobody can override it — rigid on purpose

RBAC

Role-based access control

Who decides: permissions belong to **ROLES**

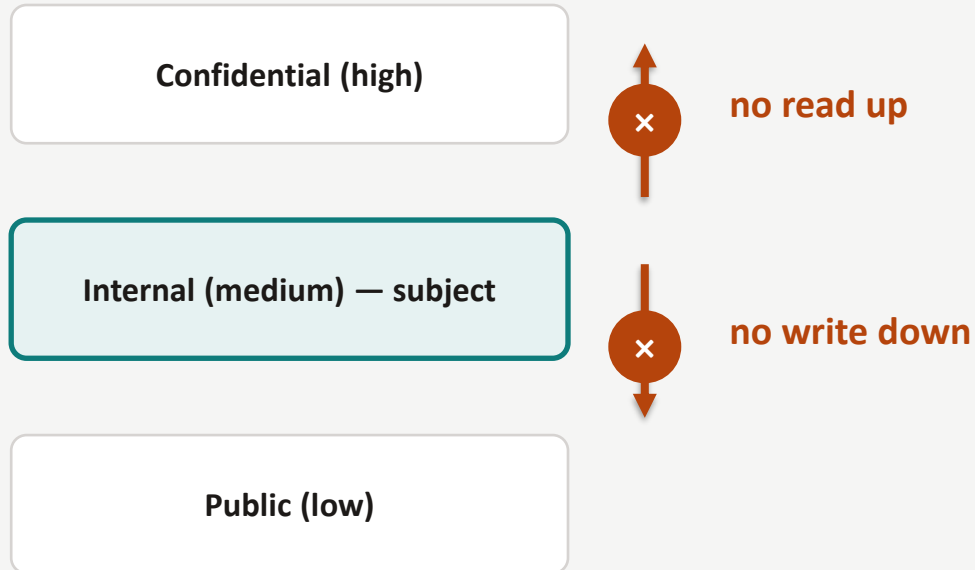
- People are assigned to **roles**: finance, sales, warehouse, developer, **IT** (Information Technology) admin
- The everyday model — it scales; [NIST model, ANSI INCITS 359](#)
- Exercise 2.3 builds BlueFern's matrix

Where systems are going: **ABAC (Attribute-Based Access Control)** adds conditions — time of day, location, device state (recognition level today).



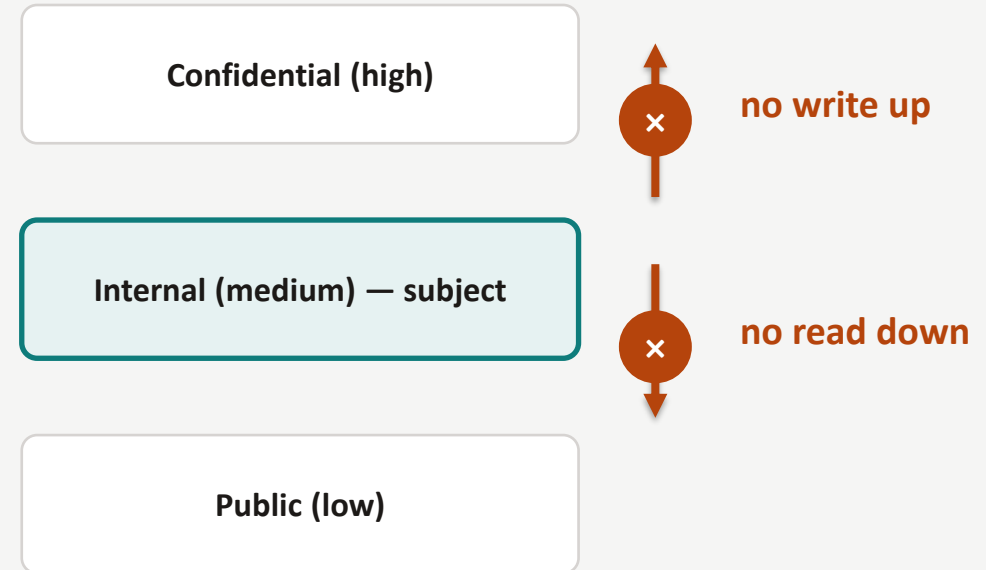
Bell-LaPadula and Biba: two rules each

Bell-LaPadula (1973) — protects CONFIDENTIALITY



read down and write up are allowed — secrets must not flow down

Biba (1977) — protects INTEGRITY

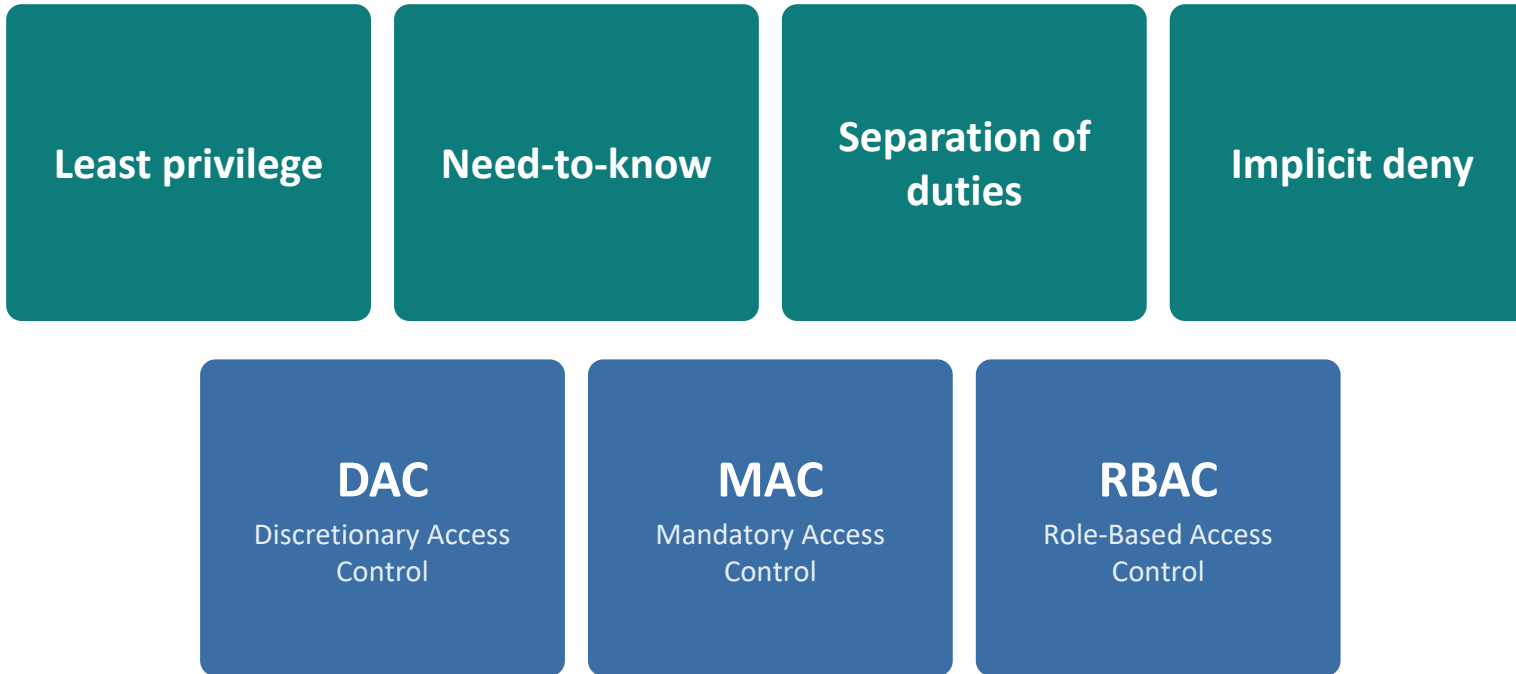


read up and write down are allowed — untrusted data must not flow up

Recognition level only: know the two names and the four rules — no proofs, no state machines.



Micro-activity — seven access-control terms (4 min)



For each term: **say the definition** before the card turns, then **point to one place in the BlueFern profile** where it is violated.

Watch at home



[Access Controls - CompTIA Security+ SY0-701 - 4.6](#)

Professor Messer (Messer Studios) · 7:49

Least privilege, then **MAC**, **DAC**, role-, rule- and attribute-based access control.

Flash-cards

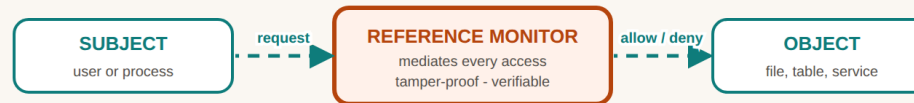
Five cards for Lesson 3 are in the hand-out and the lecture module: principles, models, Bell-LaPadula versus Biba.



Schematic — access control in one picture

Access control in one picture

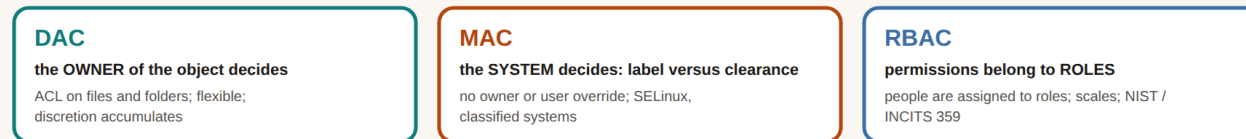
Subject, reference monitor, object - four principles - three models - two classical level models (Lesson 3)



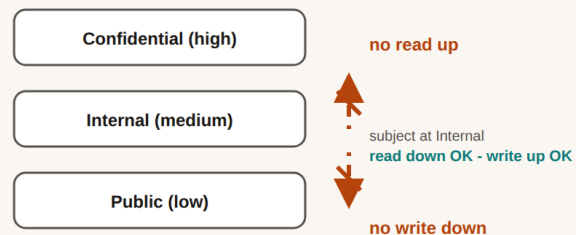
Four principles

- Least privilege**
minimum rights for the task
- Need-to-know**
only the information the task needs
- Separation of duties**
no critical task by one person
- Implicit deny**
not permitted = refused

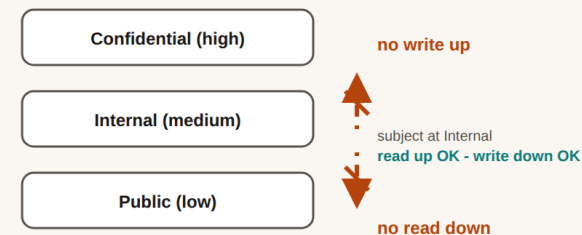
Who decides?



Bell-LaPadula (confidentiality)



Biba (integrity)



Secrets must not flow down (Bell-LaPadula); untrusted data must not flow up (Biba). Recognition level only - no proofs in this course.

Exercise 2.3: six roles x six resources with R / W / A / -, then the separation-of-duties conflicts (expect three).

Cyber.SoHo - CS 474 Class 2 - Lesson 3

Top: subject, reference monitor, object, and the four principles that shape the rules. Middle: who decides under each model. Bottom: the two classical models as arrows on three levels - confidentiality forbids reading up and writing down; integrity forbids writing up and reading down.



Real-life example — the role matrix and its three conflicts

Role	Customer DB	Web-shop admin	HR folder	Payment reports	Source code	Backups
CEO (Chief Executive Officer)	R	-	R	R (approves)	-	-
Finance (3)	R	-	-	RW	-	-
Sales (12)	RW	RW	-	-	-	-
Warehouse (10)	-	R	-	-	-	-
Developer (2)	-	-	-	-	RW	-
IT (Information Technology) admin (2)	A	A	A (no read)	A (no read)	A	A (second person)

R = read · W = write · A = administer · - = no entry (**implicit deny**). Rust cells: the conflicts found today.

Conflicts: developer reaches production customer data · finance records and approves payments · one administrator holds every right.

Access Decision Simulator - the BlueFern Trading Inc. role matrix, the three models, and the separation-of-duties conflicts

The matrix gives six roles the rights they need on six resources (R = read, W = write, A = administer, - = nothing). Each step evaluates one access request under RBAC, DAC or MAC, names the principle applied (least privilege, need-to-know, separation of duties, implicit deny), and records the verdict. The last steps show Bell-LaPadula and Biba on a three-level ladder. Pause at any step to discuss.

Start Restart Copy log Copy code Download matrix + decisions (CSV)

Step 9 of 12

Target role matrix (RBAC) conflicts found: 3

Role / Resource	Customer DB	Web-shop admin	HR folder	Payment reports	Source code	Backups
CEO	R	-	R	R	-	-
Finance	R	-	-	RW	-	-
Sales	RW	RW	-	-	-	-
Warehouse	-	R	-	-	-	-
Developer	-	-	-	-	RW	-
IT admin	A	A	A (no read)	A (no read)	A	A

Decision

Subject: subject at level Internal

Object: object at level Confidential

Action: read

Model: Bell-LaPadula (confidentiality)

Rule applied: No read up: a subject may not read an object above its clearance

Verdict: **DENIED**

Confidential (high) object (read)

Internal (medium) subject

Public (low)

Execution steps (read this window when paused)

Rules: 1 rule

Rule: Mandatory: the system compares the subject's clearance (Internal) with the object's label (Confidential)

Verdict: DENIED

Under mandatory access control, labels are set centrally and neither the owner nor the user can override them. A warehouse account with clearance Internal cannot read an object labelled Confidential, whatever any owner says. Used where the data is sensitive enough to remove human discretion.

Step 9 - subject at level Internal wants to read on object at level Confidential

Model: Bell-LaPadula (confidentiality)

Rule: No read up: a subject may not read an object above its clearance

Verdict: DENIED

Bell-LaPadula protects confidentiality. Simple security property: no read up. An Internal-level subject (sales) may not read a Confidential object (the payment report).

Task

Build the 6 × 6 matrix, test 12 requests under the three models and record the conflicts.

Where it returns

Exercise 2.3 → Binder Part 2 · Parts 7, 8 and 10.



Self-check — Lesson 3 (1/2): four questions, one answer each

1

Thirty BlueFern laptops give every employee local administrator rights 'to install printers'. Which principle is violated?

- a) Implicit deny
- b) No read up
- c) Separation of duties
- d) Least privilege

2

Under which model does the OWNER of a folder decide who may read it?

- a) Bell-LaPadula
- b) Discretionary access control (DAC)
- c) Mandatory access control (MAC)
- d) Role-based access control (RBAC)

3

A warehouse account with clearance 'Internal' requests a payment report labelled 'Confidential'. The system refuses, and no owner can change that. Which model is at work?

- a) Attribute-based access control (ABAC)
- b) Discretionary access control (DAC)
- c) Mandatory access control (MAC)
- d) Implicit allow

4

'No read up, no write down' are the two rules of which model, protecting which property?

- a) Bell-LaPadula - confidentiality
- b) DAC - accountability
- c) Biba - integrity
- d) RBAC - availability

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade.



Self-check — Lesson 3 (2/2): two questions, several answers each

5

Which of these BlueFern arrangements are separation-of-duties conflicts? (select 3)

- a) Finance records payments and also approves them
- b) The warehouse role can read orders in the shop admin panel
- c) One IT (Information Technology) administrator holds every right, including the backups
- d) Sales can read and update customer records
- e) The **CEO** (Chief Executive Officer) can read the payment reports
- f) The two developers can reach the live customer database

6

Which statements about the reference monitor are correct? (select 2)

- a) It is a document signed by management
- b) It grants access by default when unsure
- c) It replaces authentication
- d) It exists only in military systems
- e) It must mediate every access request - a checkout reachable by editing a **URL** (Uniform Resource Locator) means it does not
- f) It must be tamper-proof and small enough to be verified

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade. Answers and explanations: lecture module and hand-out.



Two families of law

Computer-crime law

applies to **YOU**

- What every **person** may not do to a computer system
- No access, interference or interception without authorization
- Canada: Criminal Code · United States: **CFAA** (Computer Fraud and Abuse Act) · **EU** (European Union): Directive 2013/40/EU

Privacy (data-protection) law

applies to **ORGANIZATIONS**

- What every **organization** must do with the personal information it holds
- Collect it lawfully, protect it, report when protection fails
- Canada: **PIPEDA** (Personal Information Protection and Electronic Documents Act) · Québec: Law 25 · **EU**: **GDPR** (General Data Protection Regulation)

For information only, not legal advice — read the official texts linked in this deck and in the lecture module.



Computer-crime law: no permission, no testing

Canada — Criminal Code

s. 342.1 — unauthorized use of a computer

obtaining a computer service, or intercepting a function of a computer system, without authorization — up to 10 years

s. 342.2 — devices for that purpose

making, possessing or distributing a device or software designed for it

s. 430(1.1) — mischief to data

destroying, altering or interfering with data or its lawful use — where a denial-of-service “test” falls

s. 184 — interception

intercepting private communications — where capturing other people’s traffic falls

Three facts

1

The unauthorized act **is** the offence — no damage is required.

2

Intent to learn, to help or to “just look” is not a defence.

3

Foreign law applies at the same time:
[CFAA](#) · [Directive 2013/40/EU](#) · [Ley Orgánica 10/1995](#)



Three course rules — and what authorization means

1

Never scan, test, capture or attack anything but the **designated laboratory system** — not the campus network, not your home router, not a website that “will not mind”.

2

No **OSINT (Open-Source Intelligence)** on real people or real organizations — the course material is fictional by design.

3

If you are not certain that you have authorization, **you do not have it** — stop and ask.

Authorization =

the **written** agreement of the system’s **owner**, naming the systems, the period and the permitted actions.

X a friend’s “sure, go ahead”

X an intern’s e-mail

✓ the scope document of the laboratory

Template: [Cyber.SoHo Legal Notice, Annex D](#)

Your acknowledgement (Annex A) is signed before the first laboratory — form provided separately.



Privacy law: PIPEDA, Law 25, GDPR

Personal information = information about an identifiable individual — a name with an address, an e-mail, an order history. BlueFern holds about 120,000 such records.

PIPEDA — Canada

- Private sector, commercial activity
- Ten fair information principles: accountability, consent, limiting collection, safeguards, openness...
- Breach of security safeguards: report to the **OPC** (Office of the Privacy Commissioner of Canada); notify individuals when there is a **real risk of significant harm**; keep a record of every breach for 24 months ([OPC guidance](#))

Law 25 — Québec

- A person in charge of personal information
- A **confidentiality incident register**
- Notify the **CAI** (Commission d'accès à l'information du Québec) and the individuals when there is a risk of serious injury
- Privacy impact assessments; penalties based on turnover

GDPR — European Union

- Applies to **EU** (European Union) residents' data, wherever the company is
- A lawful basis for every use; rights of the **data subject**
- Duties of the **controller** and the **processor**
- Supervisory authority notified within **72 hours**; fines up to 4 % of worldwide turnover

BlueFern is a Québec company with 300 EU customers: all three apply at once. Sprint 2 writes its breach-notification procedure.



Coordinated disclosure and ethics

Found a flaw you were not looking for? — coordinated vulnerability disclosure (CVD)

1 Stop

do not probe further

2 Record

what you saw, and when

3 Report privately

to the owner's security contact — /.well-known/security.txt ([RFC 9116](#))

4 Allow time

about 90 days is a common norm

5 Publish nothing

before the fix — then only what was agreed

Standards and coordinators

[ISO/IEC 29147](#) (vendor side) · [CISA CVD process](#) · [Canadian Centre for Cyber Security](#)

Bug bounty

A written invitation to test defined systems: its rules are the limits of your authorization.

Code of ethics — [ISC2](#)

- Protect society, the common good and the infrastructure
- Act honorably, honestly, justly, responsibly and legally
- Provide diligent and competent service
- Advance and protect the profession



Micro-activity — legal or not? (3 min)

1

You run the Class 4 scan against the laboratory virtual machine named in the scope document, during the laboratory window.

Legal or not? Show of hands

2

After class you run the same scan against the café's Wi-Fi router "for practice".

Legal or not? Show of hands

3

A friend says his employer "will not mind" if you test their web shop.

Legal or not? Show of hands

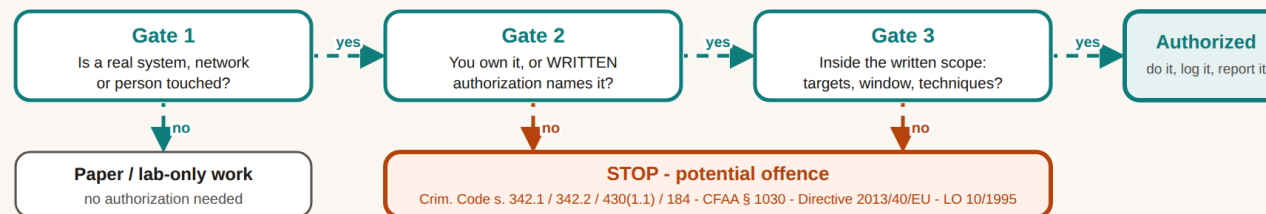
The interactive example of this lesson runs six more situations — including an accidental finding and a lost laptop with customer data.



Schematic — three gates, one privacy branch

Before any test: three gates. After any incident: one branch.

Computer-crime law applies to you; privacy law applies to the organization (Lesson 4)



No damage required. No intent required. Verbal permission and permission from a non-owner are worth nothing. Not sure = not authorized.

Privacy branch - personal information exposed at BlueFern (120,000 customer records)

PIPEDA (Canada) breach of security safeguards + real risk of significant harm
duty: report to the OPC - notify individuals - keep the record 24 months

Law 25 (Québec) confidentiality incident with a risk of serious injury
duty: notify the CAI and the individuals - incident register - person in charge

GDPR (EU customers) personal-data breach - controller
duty: supervisory authority within 72 hours - individuals when high risk

Accidental finding on a real system

- stop - do not probe further
- record what you saw
- report privately to the owner
- (/well-known/security.txt - RFC 9116)
- allow time to fix (about 90 days)
- publish nothing before the fix

= coordinated vulnerability disclosure
(ISO/IEC 29147; bug-bounty rules = your limits)

For information only, not legal advice - read the official texts linked in this module. Course rule: no OSINT on real people or organizations, ever.

Written form of gates 2 and 3 = the scope and authorization statement of Binder Part 4; the privacy branch = the breach-notification procedure of Binder Part 10.

Cyber.SoHo - CS 474 Class 2 - Lesson 4

Top: the three questions to answer before touching any system, and where a 'no' leads. Bottom: the three privacy laws that reach BlueFern's customer records, with the duty each imposes after a breach, and the disclosure path for an accidental finding.



Real-life example — legal or not? nine situations

Task

Pass nine situations through three gates (real system? written authorization? in scope?) or the privacy branch (exposed? real risk of significant harm? whom to notify, by when?).

How it relates to today

The gates are computer-crime law applied before you act; the branch is privacy law applied after an incident.

Where it returns

The **scope and authorization statement** of Binder Part 4 (Class 4) • the breach-notification procedure of Part 10 • “what to say to whom” in Part 6.

Authorization and Privacy Gate Checker - "legal or not?" before any test, and what the law requires after a privacy incident

Each scenario walks through the three authorization gates (real system? written authorization? inside the written scope?) or through the privacy branch (personal data exposed? real risk of significant harm? whom to notify, by when?). The tiles show which laws apply; the clock shows the GDPR 72-hour deadline. Pause at any step to discuss.

[Start](#) [Restart](#) [Copy log](#) [Copy code](#) [Download verdict table \(CSV\)](#)

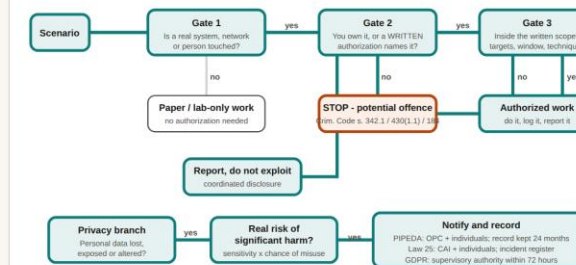
Scenario 7 of 9 - a stop: pause and discuss why.

Scenario

7. A BlueFern laptop is lost on the bus. It holds the unencrypted export of the 120,000 customer records (names, addresses, e-mails, order history) - and 300 of the customers live in the European Union.

Breach of security safeguards - notify and record

The gates (teal = path taken; rust = stop)



Which law applies here?

[Canada - Criminal Code](#) [Canada - PIPEDA](#) [Québec - Law 25](#)

Execution steps (read this window when paused)

Scenario 7: A BlueFern laptop is lost on the bus. It holds the unencrypted export of the 120,000 customer records (names, addresses, e-mails, order history) - and 300 of the customers live in the European Union.

Verdict: Breach of security safeguards - notify and record

Privacy branch. Personal data was exposed; the risk of significant harm is real (identifiers plus addresses, no encryption, unknown finder). Under PIPEDA BlueFern reports to the Office of the Privacy Commissioner of Canada and notifies the affected individuals as soon as feasible, and keeps a record of the breach for 24 months. Under Québec's Law 25 it notifies the Commission d'accès à l'information and the individuals, and enters the incident in its register. For the 300 EU residents the GDPR applies: the supervisory authority must be notified within 72 hours of becoming aware. Disk encryption would have changed every answer - which is why it is in Binder Part 5.

The interactive example in the lecture module and the hand-out: **Start • Pause • Restart • Copy • CSV (Comma-Separated Values)**; every step is explained in its log window.



Review — Lesson 4: videos and flash-cards

Watch — each under 15 minutes (click the title)



Privacy - CompTIA Security+ SY0-701 - 5.4

Professor Messer (Messer Studios) · 5:21

GDPR (General Data Protection Regulation) from the organization's side: data subject, controller, processor, right to be forgotten.



What is PIPEDA and does it apply to my business?

Office of the Privacy Commissioner of Canada (official channel) · short explainer, well under 15 min

The federal regulator explains what **PIPEDA** (Personal Information Protection and Electronic Documents Act) is and which businesses it applies to.

Flash-cards — say the answer before you turn the card

1

No permission, no testing

2

Personal information and PIPEDA

3

Law 25 and the GDPR

4

Coordinated vulnerability disclosure

5

The three course rules

The backs of the cards are in the hand-out and the lecture module.



Self-check — Lesson 4 (1/2): four questions, one answer each

1

A classmate scans the café's Wi-Fi router 'for practice' and causes no damage. Under Canadian law this is:

- a) Potentially an offence under Criminal Code s. 342.1, because the act is unauthorized - damage and intent to harm are not required
- b) Legal, because a student is allowed to practise
- c) Legal, because the router is on a public Wi-Fi
- d) Legal, because nothing was damaged

2

Which of the following counts as valid authorization to test a system?

- a) A friend's verbal assurance that his employer 'will not mind'
- b) The fact that the site has a security page
- c) A written document from the owner naming the systems, the time window and the permitted actions
- d) An e-mail from a classmate who works there as an intern

3

A BlueFern laptop with the unencrypted customer export is lost. Under PIPEDA (Personal Information Protection and Electronic Documents Act), what must the company do?

- a) Pay a fine to the customers directly
- b) Report the breach to the Privacy Commissioner of Canada, notify the affected individuals, and keep a record of the breach for 24 months
- c) Delete the customer database to limit the damage
- d) Nothing, unless a customer complains

4

While ordering a part, you see a real supplier's database password on an error page. What is the correct action?

- a) Ignore it; it is not your system
- b) Post it on social media so that the supplier reacts faster
- c) Try the password to confirm the problem, then report it
- d) Stop, record what you saw, report it privately to the owner's security contact, and give them time to fix it before saying anything publicly

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade.



Self-check — Lesson 4 (2/2): two questions, several answers each

5

Which of the following actions require **WRITTEN** authorization from the system owner before you do them? (select 3)

- a) Capturing traffic on a shared Wi-Fi
- b) Reading the text of Criminal Code s. 342.1 on the Justice Laws website
- c) Running a port scan against a server
- d) Running a vulnerability scanner against a web application
- e) Writing an acceptable use policy for BlueFern
- f) Drawing BlueFern's network map from the company profile

6

Which statements about the **GDPR (General Data Protection Regulation)** are correct as presented in Lesson 4? (select 2)

- a) A personal-data breach must be notified to the supervisory authority within 72 hours of becoming aware of it
- b) It allows unlimited use of personal data once collected
- c) It applies only to companies with more than 250 employees
- d) It replaces **PIPEDA** (Personal Information Protection and Electronic Documents Act) for Canadian companies
- e) It applies to the personal data of people in the **EU** (European Union) even when the company is in Canada
- f) It gives the controller the right to keep breaches secret

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade. Answers and explanations: lecture module and hand-out.



The McCumber cube: 27 questions

Defence in depth (Class 1): independent layers, so that the failure of one does not defeat the whole. The cube checks that no property is left unprotected in any state.

Axis 1 — Security goal

- **Confidentiality**
- **Integrity**
- **Availability**
- the three properties of Class 1

Axis 2 — State of the information

- **Storage** — at rest: disk, database, backup
- **Transmission** — moving across a network
- **Processing** — being worked on by a program or a person

Axis 3 — Kind of countermeasure

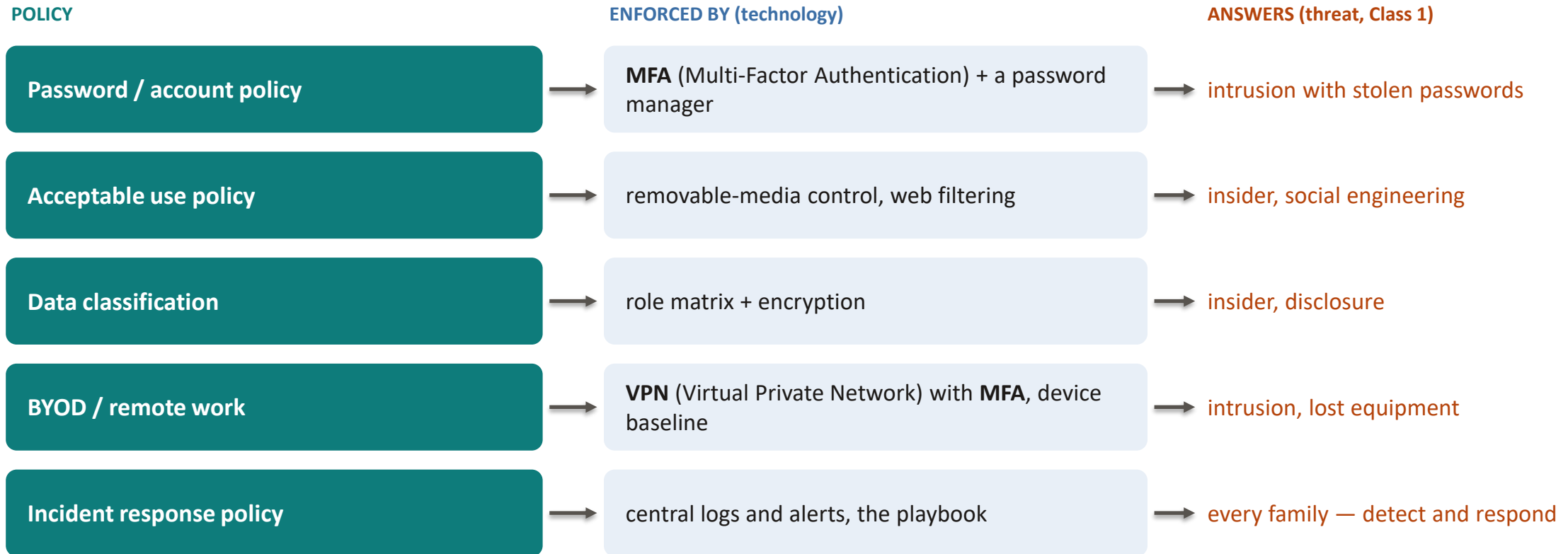
- **Technology** — encryption, firewalls, permissions, backups, logs
- **Policy and practice** — the rules of Lesson 2
- **People** — education, training, awareness

$3 \times 3 \times 3 = 27$ cells. For each: for this goal, in this state, what countermeasure of this kind do we have?

An **empty cell** is a question for the risk register (Class 6) · an **empty face** is a problem now — BlueFern today: no policy, no training.



Where policies meet technology



A policy without technology is an intention; a technology without a policy is undefined. People sit in every pair: they read the rule, use the tool and report what looks wrong.



Micro-activity — place two controls, then a Zen break

1

Full-disk encryption on the laptops

Goal?

State?

Kind?

2

Phishing-awareness training

Goal?

State?

Kind?

Zen break — 2 minutes

- Stand up
- Three slow breaths
- Look at something six metres away
- Stretch

After the break

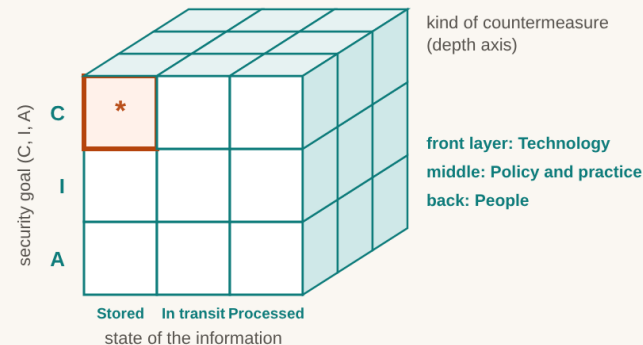
Exercise 2.1 network map · 2.2 two policies · 2.3 role matrix
→ Binder Part 2, due Wednesday, October 7, 23:59



Schematic — the cube and the policy-technology pairs

The McCumber cube - 27 questions - and where policies meet technology

Goal x state of the information x kind of countermeasure; each cell asks 'what protects this?' (Lesson 5)



*** worked cell: C x Stored x Technology**
= full-disk encryption on the 30 laptops

empty cell = a question for the risk register (Class 6),
 not automatically a gap

empty FACE (no policy, no training - BlueFern today)
 = a problem before any arithmetic

Attack test (interactive example): people passed - policy on paper passed - mail filter passed - endpoint STOPPED - logs DETECTED - backups not needed.

Cyber.SoHo - CS 474 Class 2 - Lesson 5 - McCumber cube: John McCumber, 1991

Policy - technology - threat: the pairs of the BlueFern plan

Password / account policy → MFA + password manager

answers: intrusion (stolen passwords)

Acceptable use policy → removable-media control, web filter

answers: insider, social engineering

Data classification → role matrix + encryption

answers: insider, disclosure

BYOD / remote work → VPN with MFA, device baseline

answers: intrusion, loss of equipment

Incident response policy → central logs + alerts, playbook

answers: all families (detect, respond)

**A policy without technology is an intention;
 a technology without a policy is undefined.**

People sit in every pair: read the rule, use the tool, report what looks wrong.

Left: the cube's three axes - goal, state of the information, kind of countermeasure - drawn in isometric view with one worked cell. Right: five policies of Lesson 2, each paired with the technology that enforces it and the threat family (Class 1) it answers.



Real-life example — placing BlueFern's controls in the cube

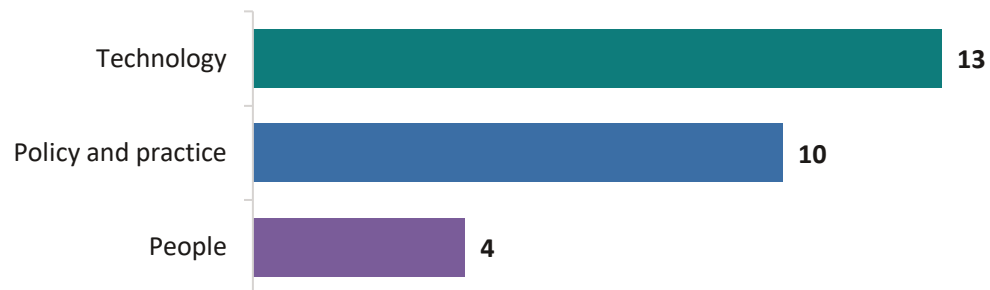
Task

Place the 12 controls of BlueFern's plan in the cube, read the coverage, then run one phishing attack through six layers.

Where it returns

Exercise 2.1 trust zones → Binder Part 2 · controls designed in Parts 5, 6, 7 · all placed on the target architecture of Part 8.

Cells filled per kind (12 controls, 17 of 27 cells)



McCumber Cube Control Placer - where each BlueFern Trading Inc. control sits, and why one layer is never enough

The cube has three axes: the security goal (confidentiality, integrity, availability), the state of the information (storage, transmission, processing) and the kind of countermeasure (technology, policy and practice, people). Each step places one control of the BlueFern plan into its cells; the coverage grows; then one phishing attack runs through the layers to show how they stack. Pause at any step to discuss.

Start Restart Copy log Copy code Download placement table (CSV)

Attack test: layer 5 of 6

Control being placed

Attack test - layer 5

The cube, unfolded - rows: goal (C, I, A); columns: state of the information (Stored = storage, Transit = transmission, Process = processing); one face per kind of countermeasure

Technology				Policy and practice				People			
	Stored	Transit	Process		Stored	Transit	Process		Stored	Transit	Process
C	2	3	2	C	2		1	C			2
I			1	I	1		2	I			1
A	1	2		A	2	1	1	A			1

Coverage 17 of 27 cells

teal = technology, blue = policy and practice, purple = people (placements per kind)

One phishing attack against the layers (runs after the placements)

1 People awareness training 2 Policy macro standard 3 Technology e-mail filter 4 Technology patched endpoint, no admin 5 Technology segmentation + logs 6 Policy + technology tested backups + playbook

Execution steps (read this window when paused) reduces the probability, it does not remove it - the layer is passed.

Layer 2 (policy): the macro standard says 'macros from the Internet disabled' - but the standard is only words until technology enforces it. Passed on paper.

Layer 3 (technology, e-mail filter): the macro is a new variant, no signature matches. Passed. Two technologies and one rule have now failed - this is normal, and the reason there are more layers.

Layer 4 (technology, endpoint): macros from Internet documents are blocked by configuration, the laptop is patched and the user has no administrator rights. The payload cannot run. STOPPED - prevention.

Layer 5 (technology, monitoring): the blocked-macro event reaches the central log; the alert is read two minutes later. DETECTED - the company now knows a phishing campaign is running and warns the other 37 employees.

Attack test: people, policy on paper and the mail filter fail; the **endpoint stops** the macro; the **central log detects** it two minutes later.



Review — Lesson 5: videos and flash-cards

Watch — each under 15 minutes (click the title)



[Defense in Depth - CompTIA Network+ N10-008 - 4.1](#)

Professor Messer (Messer Studios) · 10:02

Layers in practice: segmentation, screened subnets, separation of duties, **NAC** (Network Access Control), honeypots.

Flash-cards — say the answer before you turn the card

1

McCumber cube

2

The three states of information

3

The three kinds of countermeasure

4

Policy-technology pairs

5

Why defence in depth works

The backs of the cards are in the hand-out and the lecture module.



Self-check — Lesson 5 (1/2): four questions, one answer each

1

Full-disk encryption on the staff laptops occupies which cell of the McCumber cube?

- a) Confidentiality - transmission - technology
- b) Confidentiality - storage - technology
- c) Availability - transmission - policy
- d) Integrity - processing - people

2

Phishing-awareness training occupies which kind of countermeasure, and why is it special?

- a) None - training is not a security control
- b) Policy - because attendance is mandatory
- c) Technology - because it is delivered on a computer
- d) People - it is the only countermeasure that acts on human judgment, which every state of information passes through

3

'A policy without technology to enforce it is an intention.' Which pair illustrates the sentence correctly?

- a) The password policy is enforced by printing it on the wall
- b) The data classification policy is enforced by the **DDoS** (Distributed Denial of Service) protection
- c) The macro rule in the standard is enforced by the endpoint configuration that blocks macros from Internet documents
- d) The incident response policy is enforced by the firewall

4

In the attack test, three layers were passed before the endpoint configuration stopped the macro. What does this show?

- a) That defence in depth works: the failure of some layers does not defeat the whole, and a later layer both stopped and detected the attack
- b) That the company should buy a stronger mail filter and nothing else
- c) That training makes employees open attachments
- d) That the first three layers are useless and should be removed

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade.



Self-check — Lesson 5 (2/2): two questions, several answers each

5

Which are the three states of information on the McCumber cube's second axis? (select 3)

- a) Encryption
- b) Transmission
- c) Storage
- d) Technology
- e) Confidentiality
- f) Processing

6

Which statements about an EMPTY cell of the cube are correct? (select 2)

- a) An empty cell in 'processing' can be fixed by encryption at rest
- b) Only the technology face matters
- c) A whole empty face - for example no policy controls at all - is a problem before any arithmetic
- d) It means the company has been breached
- e) It is a question for the risk register: is there a threat there, and what would it cost?
- f) It must always be filled immediately with a product

FORMATIVE, not summative: this self-check is for practice only and does NOT count toward your grade. Answers and explanations: lecture module and hand-out.



Links (1/2) — rules, laws and regulators

- [Cyber.SoHo - Legal Notice and Terms of Use \(v2.0\)](#) — the rules of every lab and project; Annex D authorization template
- [Criminal Code of Canada, section 342.1 \(Justice Laws Website\)](#) — unauthorized use of a computer
- [Criminal Code of Canada, section 430 \(mischief\)](#) — mischief, including to computer data
- [Criminal Code of Canada, section 184 \(interception\)](#) — interception of private communications
- [US Computer Fraud and Abuse Act, 18 U.S.C. § 1030 \(Cornell LII\)](#) — US (United States) federal computer-crime statute
- [EU Directive 2013/40/EU \(EUR-Lex\)](#) — attacks against information systems
- [Spain - Ley Orgánica 10/1995, Código Penal \(BOE\)](#) — the Spanish Criminal Code
- [PIPEDA - Office of the Privacy Commissioner of Canada](#) — Canada's private-sector privacy law
- [OPC - Mandatory reporting of breaches](#) — reporting breaches of security safeguards
- [Commission d'accès à l'information du Québec \(Law 25\)](#) — Québec's regulator (Law 25)
- [EU GDPR, Regulation \(EU\) 2016/679 \(EUR-Lex\)](#) — the EU (European Union) privacy regulation
- [Canadian Centre for Cyber Security](#) — Canada's national authority
- [CISA - Coordinated Vulnerability Disclosure Process](#) — national coordinator for disclosure
- [ISC2 Code of Ethics](#) — the four canons
- [VirusTotal - URL check](#) — check every link before you open it (Annex C)

Every address is an official site. Check any link with [VirusTotal](#) before you open it (Cyber.SoHo Legal Notice, Annex C).



Links (2/2) — standards, references and videos

- [IANA - Service Name and Transport Protocol Port Number Registry](#) — official registry of port numbers
- [IETF - RFC 1918, Address Allocation for Private Internets](#) — the private address ranges
- [IETF - RFC 9116, security.txt](#) — security.txt — where to report a flaw
- [ICANN - Internet Corporation for Assigned Names and Numbers](#) — coordinates the domain-name system
- [NIST - National Institute of Standards and Technology](#) — US (United States) standards body
- [NIST SP 800-63B - Digital Identity Guidelines](#) — modern password rules
- [NIST - Role-Based Access Control project](#) — origin of the **RBAC** (Role-Based Access Control) model
- [NIST Computer Security Resource Center - Glossary](#) — official definitions of today's terms
- [NIST Cybersecurity Framework \(CSF\) 2.0](#) — the Govern function holds policies
- [ISO/IEC 27001 - Information security management systems](#) — management-system standard; control 5.1 policies
- [ISO/IEC 29147 - Vulnerability disclosure](#) — receiving vulnerability reports
- [SANS Institute - Information Security Policy Templates](#) — free policy templates — adapt, never copy
- [CIS - Center for Internet Security \(Benchmarks\)](#) — configuration baselines (Class 5)
- [Professor Messer - free CompTIA Security+ SY0-701 course index](#) — Security+ video index with runtimes
- [Professor Messer - free CompTIA Network+ N10-008 course index](#) — Network+ video index with runtimes
- [Crash Course Computer Science #29 - The Internet \(official page\)](#) — the Lesson 1 video page
- [OPC - Introduction to PIPEDA \(video series\)](#) — the **PIPEDA** (Personal Information Protection and Electronic Documents Act) explainer videos
- [Pearson - Computer Security Fundamentals, 4th edition \(Easttom\)](#) — publisher of the textbook

Every address is an official site. Check any link with [VirusTotal](#) before you open it (Cyber.SoHo Legal Notice, Annex C).



Before you leave

Exit ticket (2:55–3:00)

- One term from today you can define without notes
- One term you still cannot
- Did you submit Binder Part 1? If not, what is missing?

Binder Part 2 — due Wed Oct 7, 23:59

- **Exercise 2.1** network map with trust zones
- **Exercise 2.2** acceptable use policy (1 page) + password policy (½ page)
- **Exercise 2.3 RBAC** (Role-Based Access Control) matrix 6×6 + a five-line conflicts note
- Summary only — the exercise sheets come separately

At home — 2 hours

- Easttom, chapter 10 + chapter 2 (TCP/IP, **DNS** (Domain Name System), **HTTP** (HyperText Transfer Protocol))
- Finish Binder Part 2 on the **LMS** (Learning Management System)
- Read the [Cyber.SoHo Legal Notice](#) — acknowledgement before the first lab

Next class — Thursday, October 8, 2026 · Class 3: How Attackers Think

